

SEGURIDAD PERIMETRAL Y FIREWALL LOCAL

Segmentación de red con pfSense y defensa en profundidad con
iptables/UFW

Caso práctico: red corporativa simulada “Banco Coop”

Por: Jonathan Gomez



Topología del laboratorio utilizada en el ejercicio.

Documento de laboratorio y evidencias técnicas

1. Resumen ejecutivo

Este proyecto documenta la evaluación y el endurecimiento de una red virtual mediante pfSense como firewall perimetral y reglas de firewall local en Linux. El ejercicio parte de una política permisiva, identifica servicios expuestos en un servidor de laboratorio y aplica segmentación basada en origen, destino, protocolo y puerto.

El objetivo es demostrar el ciclo de trabajo de un control técnico: establecer una línea base, definir una matriz de acceso, implementar reglas específicas, validar conexiones permitidas y bloqueadas, y conservar evidencia en capturas y registros.

Objetivos

- Identificar la exposición inicial de los servicios de Metasploitable.
- Separar la red interna (LAN) de la zona de servidores (DMZ).
- Permitir solo los flujos justificados por el escenario de negocio.
- Restringir el acceso administrativo y el acceso a servicios sensibles.
- Validar el comportamiento con Nmap, curl, nc, ping y los logs de pfSense.
- Aplicar defensa en profundidad mediante firewall perimetral y firewall local.

Alcance y limitaciones

Todas las pruebas descritas corresponden a un laboratorio propio con máquinas virtuales. Metasploitable es deliberadamente vulnerable y debe mantenerse aislado; no debe exponerse directamente a Internet. Los resultados son los observados en las capturas incluidas y no representan una auditoría de una infraestructura real.

2. Topología del laboratorio

Direcciones IP documentadas:

Zona / equipo	Dirección	Función
WAN de pfSense	10.0.2.15	Interfaz externa simulada mediante NAT de VirtualBox
LAN	192.168.1.0/24	Red interna de equipos de administración/prueba
Kali Linux	192.168.1.100	Equipo de pruebas y administración autorizado
Parrot OS	192.168.1.102	Equipo que simula un proveedor autorizado para FTP
DMZ	192.168.2.0/24	Segmento de servidores
Metasploitable	192.168.2.100	Servidor vulnerable de laboratorio

La LAN y la DMZ deben comunicarse a través de pfSense para que sus reglas puedan controlar el tráfico entre segmentos. El firewall local de Metasploitable agrega una segunda capa de control.

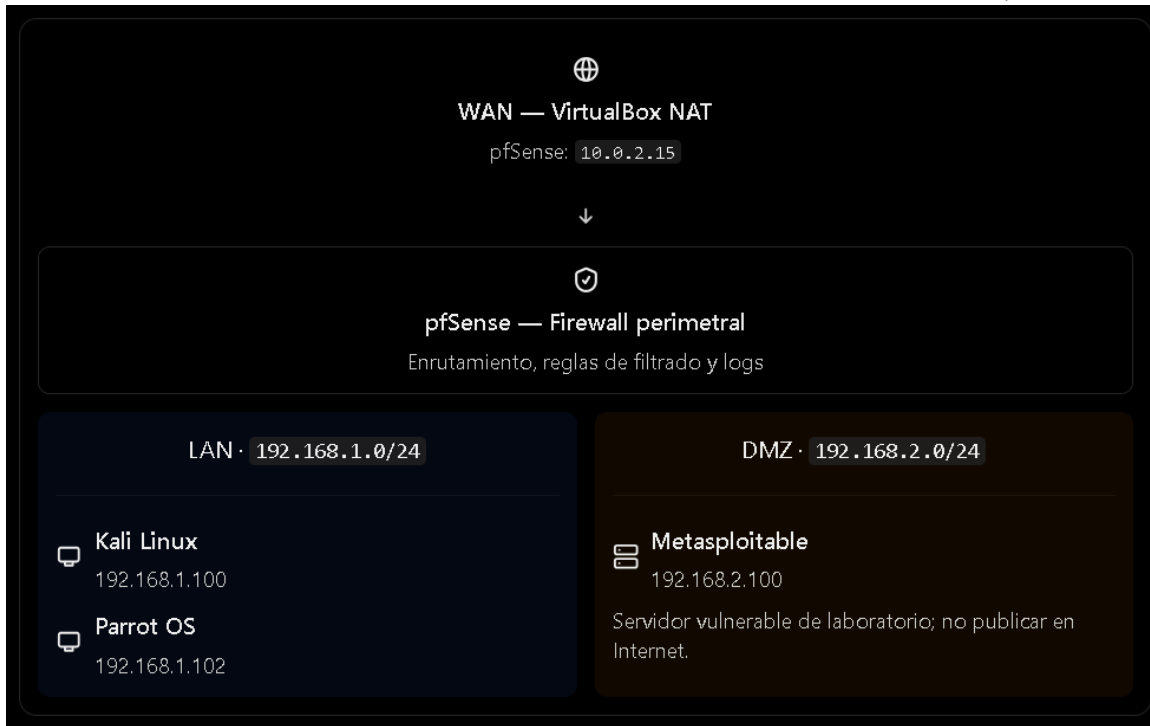


Figura 1. Topología de red documentada.

3. Evaluación inicial

Se registraron las reglas existentes en la interfaz LAN y se realizó un escaneo desde Kali hacia Metasploitable para identificar servicios accesibles antes de aplicar la política restrictiva.

3.1 Reglas existentes

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	0/0 B	*	*	*	LAN Address	443 80 22	*	*		Anti-Lockout Rule	
☐	0/5 KiB	IPv4 *	192.168.1.102	*	192.168.2.100	*	*	none		Parrot Testing	
☐	41/14.17 MiB	IPv4 *	*	*	*	*	*	none		Any	
☐	0/0 B	IPv4 TCP	KALI_ADMIN	*	DMZ_SERVERS	22 (SSH)	*	none		Permitir SSH Kali a DMZ	
☐	0/0 B	IPv4 ICMP	LAN subnets	*	192.168.2.100	*	*	none		Permitir ICMP LAN a DMZ	
☐	0/0 B	IPv4 *	*	*	This Firewall (self)	*	*	none			
☐	0/0 B	IPv4 TCP	*	*	*	22 (SSH)	*	none		Permitir SSH	
☐	0/0 B	IPv4 ICMP	*	*	*	*	*	none		Bloquear ICMP a firewall	
☐	0/0 B	IPv4 *	LAN subnets	*	*	*	*	none		Default allow LAN to any rule	
☐	0/0 B	IPv6 *	LAN subnets	*	*	*	*	none		Default allow LAN IPv6 to any rule	

Figura 2. Reglas LAN observadas antes de la segmentación.

En la captura se observa una regla amplia cuyo origen y destino aparecen como cualquier dirección. Una regla de este tipo puede permitir más tráfico del necesario y debe revisarse según el objetivo de segmentación. La evaluación

se basa en los campos visibles y en las pruebas de conectividad; el nombre descriptivo de una regla no limita su alcance si los campos de origen y destino no lo hacen.

3.2 Escaneo inicial desde Kali

```
nmap -Pn -sV --top-ports 100 192.168.2.100 -oN baseline_kali.txt
```

El registro documenta, entre otros, los siguientes servicios detectados:

Puerto	Servicio detectado	Observación
21/tcp	FTP (vsftpd 2.3.4)	Servicio de transferencia de archivos
23/tcp	Telnet	Administración sin cifrado
25/tcp	SMTP (Postfix)	Servicio de correo
53/tcp	DNS (BIND 9.4.2)	Resolución de nombres
80/tcp	HTTP (Apache 2.2.8)	Servidor web
139/445	NetBIOS/SMB (Samba)	Compartición de archivos
3306/tcp	MySQL 5.0.51a	Base de datos
5432/tcp	PostgreSQL 8.3.x	Base de datos
5900/tcp	VNC	Acceso remoto gráfico
2049/tcp	NFS	Compartición de archivos

El escaneo evidencia una superficie de exposición amplia en el servidor de laboratorio. La presencia de un puerto abierto no confirma por sí sola que exista una vulnerabilidad explotable; sí justifica validar si el servicio es necesario, si está actualizado y desde qué redes debería ser accesible.

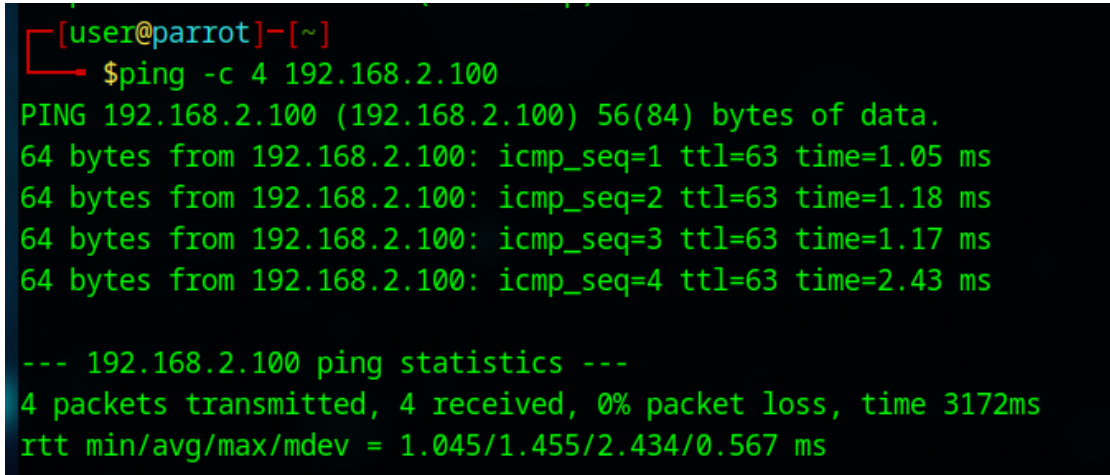
Zona	Host	Rol	Quién debe acceder	Puertos permitidos
LAN	Kali (.1.100)	Admin/ pentester	Todo lo necesario para administrar	—
LAN	Parrot (.1.102)	Usuario estándar	Solo servicios publicados de DMZ	80, 443 hacia DMZ
DMZ	Metasploitable (.2.100)	Servidor expuesto	Nadie entra salvo admin SSH	22 (solo desde Kali), 80/443 (desde LAN)
Firewall	pfSense	Gestión	Solo Kali	WebGUI/SSH

Figura 3. Salida del escaneo inicial de Nmap (fragmento).

3.3 Pruebas de conectividad inicial

```
ping -c 4 192.168.2.100
```

Las capturas registran respuestas ICMP desde Kali y Parrot hacia Metasploitable. Esto demuestra conectividad IP entre esos equipos en el momento de la prueba, pero no determina por sí solo qué puertos de aplicación están autorizados.



```
[user@parrot]~$ ping -c 4 192.168.2.100
PING 192.168.2.100 (192.168.2.100) 56(84) bytes of data:
64 bytes from 192.168.2.100: icmp_seq=1 ttl=63 time=1.05 ms
64 bytes from 192.168.2.100: icmp_seq=2 ttl=63 time=1.18 ms
64 bytes from 192.168.2.100: icmp_seq=3 ttl=63 time=1.17 ms
64 bytes from 192.168.2.100: icmp_seq=4 ttl=63 time=2.43 ms

--- 192.168.2.100 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3172ms
rtt min/avg/max/mdev = 1.045/1.455/2.434/0.567 ms
```

Figura 4. Evidencia de ping entre la LAN y la DMZ.

También se documentaron pruebas desde Metasploitable hacia la LAN e Internet que no obtuvieron respuesta. Deben interpretarse como resultados observados en ese momento: pueden depender de reglas de pfSense, rutas, DNS, políticas de ICMP o del servicio remoto.

3.4 Evaluación del tráfico desde la DMZ hacia la LAN

Objetivo

Evaluar si un servidor ubicado en la zona desmilitarizada (DMZ) puede establecer conexiones hacia equipos de la red interna y determinar si las reglas del firewall perimetral aplican la segmentación esperada.

Escenario

Origen: Metasploitable — 192.168.2.100 (DMZ).

Destino: Kali Linux — 192.168.1.100 (LAN).

Control evaluado: reglas de filtrado de pfSense en la interfaz OPT1 (DMZ).

Riesgo analizado: movimiento lateral desde un servidor potencialmente comprometido hacia la red interna.

Prueba técnica

Desde la consola de Metasploitable se ejecuta:

```
nmap -Pn -p- 192.168.1.100
```

El comando intenta identificar los puertos TCP accesibles en el equipo Kali, sin depender de una respuesta previa al descubrimiento del host.

Interpretación del hallazgo

Si el escaneo identifica puertos abiertos, existe evidencia de que determinados servicios de la LAN son accesibles desde la DMZ. Esto debe contrastarse con la política de acceso definida y las reglas de firewall aplicables.

La conectividad entre segmentos aumenta el riesgo de movimiento lateral si un atacante compromete un servidor de la DMZ y puede utilizar los servicios internos accesibles para continuar sus actividades.

Impacto potencial

Acceso no autorizado a servicios de la red interna.

Intentos de autenticación contra servicios administrativos.

Explotación de vulnerabilidades en equipos accesibles.

Propagación hacia otros sistemas, dependiendo de los permisos, las vulnerabilidades y los controles existentes.

Recomendación

Aplicar una política de mínimo privilegio entre la DMZ y la LAN. Bloquear las conexiones nuevas iniciadas desde la DMZ hacia la red interna, salvo excepciones justificadas por necesidades operativas. Registrar los intentos bloqueados y validar el resultado mediante nuevas pruebas de conectividad.

Estado de la validación

El resultado del escaneo debe adjuntarse como evidencia. Un puerto abierto demuestra accesibilidad del servicio, no un compromiso exitoso. La corrección se considerará validada cuando las conexiones no autorizadas queden bloqueadas y las excepciones legítimas continúen funcionando.

4. Matriz de acceso objetivo

La matriz define los flujos que el escenario simulado necesita. Es la referencia para implementar y probar reglas específicas.

Origen	Destino	Servicio	Decisión objetivo	Justificación
Kali 192.168.1.100	Metasploitable 192.168.2.100	TCP 2222 (SSH)	Permitir	Administración del laboratorio
LAN autorizada	Metasploitable	TCP 80 (HTTP)	Permitir	Acceso al portal simulado
Parrot 192.168.1.102	Metasploitable	TCP 21 (FTP)	Permitir	Proveedor simulado autorizado
Resto de LAN	Metasploitable	TCP 21 (FTP)	Denegar	Restringir FTP al proveedor
Cualquier origen en LAN	Metasploitable	TCP 3306 (MySQL)	Denegar	No exponer directamente la base de datos
DMZ	LAN / Internet	Tráfico nuevo no justificado	Denegar o restringir	Limitar movimiento lateral y salida no necesaria
LAN autorizada	Metasploitable	ICMP Echo Request	Permitir según necesidad	Diagnóstico controlado

Nota: las reglas de firewall se aplican en el contexto de la interfaz por la que entra el tráfico en pfSense. La política final debe considerar el orden de las reglas, las reglas existentes, el seguimiento de estado y los servicios realmente activos.

5. Implementación de reglas en pfSense

5.1 Retirar el permiso amplio

Se documentó la eliminación de una regla Any-to-Any en LAN y se conservaron las reglas necesarias para la administración del firewall. Antes de realizar cambios en un entorno real se debe exportar la configuración, asegurar un canal de recuperación y evitar deshabilitar la regla Anti-Lockout.

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	2/1.47 MiB	*	*	*	LAN Address	443 80 22	*	*		Anti-Lockout Rule	
☐	0/7 KIB	IPv4 TCP	KALI_ADMIN	*	DMZ_SERVERS	22 - 2222	*	none		Permitir SSH Kali a DMZ	
☐	0/0 B	IPv4 ICMP	LAN subnets	*	192.168.2.100	*	*	none		Permitir ICMP LAN a DMZ	
☐	0/0 B	IPv4 *	*	*	This Firewall (self)	*	*	none			
☐	0/0 B	IPv4 TCP	*	*	*	22 (SSH)	*	none		Permitir SSH	
☐	0/0 B	IPv4 ICMP	*	*	*	*	*	none		Bloquear ICMP a firewall	
☐	0/0 B	IPv4 *	LAN subnets	*	*	*	*	none		Default allow LAN to any rule	
☐	0/0 B	IPv6 *	LAN subnets	*	*	*	*	none		Default allow LAN IPv6 to any rule	

Figura 5. Reglas LAN tras retirar el permiso amplio (captura del documento original).

5.2 Publicar el portal HTTP de laboratorio

Se configuró un permiso desde la LAN hacia el servidor de la DMZ por TCP 80 y se verificó la respuesta HTTP desde Parrot. La respuesta 200 OK confirma que el servidor web respondió desde ese origen en la prueba documentada.

```
curl -I http://192.168.2.100/
```

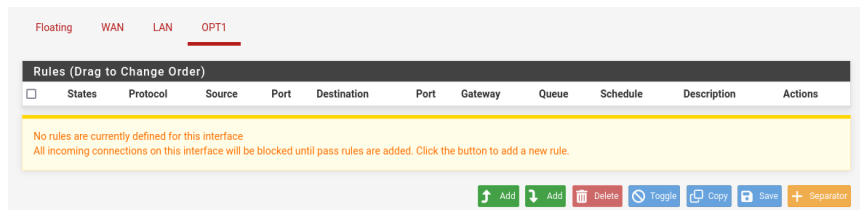


Figura 6. Respuesta HTTP del servidor de la DMZ.

5.3 Restringir FTP al proveedor simulado

Se definió un alias para identificar al equipo autorizado y una regla para permitir TCP 21 hacia el servidor DMZ desde esa dirección. Se añadió una regla de denegación para el resto de la LAN. El orden y la ausencia de reglas más amplias que permitan el mismo flujo deben verificarse.

```
nc -zv 192.168.2.100 21
```

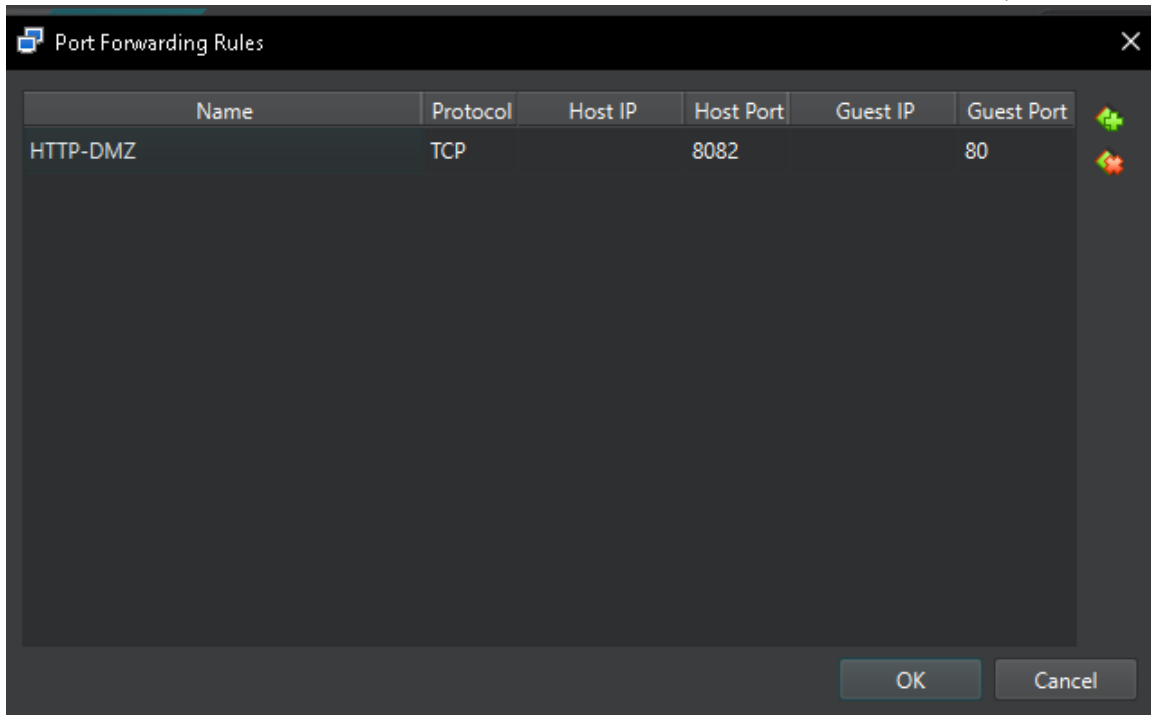


Figura 7. Alias de direcciones para identificar los equipos autorizados.

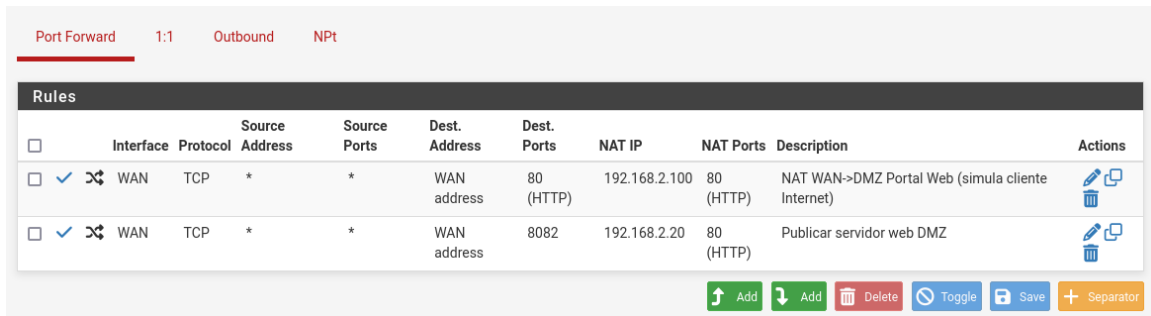


Figura 8. Regla de permiso FTP para el proveedor.

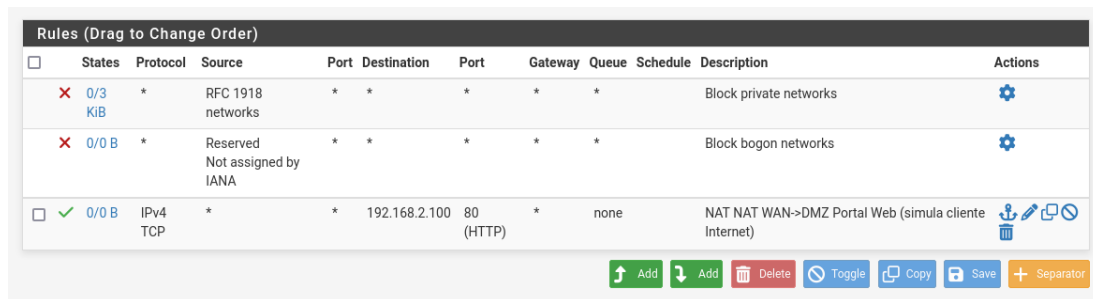


Figura 9. Prueba de conexión al puerto FTP desde el equipo autorizado.

La evidencia de logs muestra intentos bloqueados desde una máquina sin permiso. Para una validación completa, debe guardarse también la prueba de conexión fallida desde ese origen y correlacionarse con el registro de pfSense.

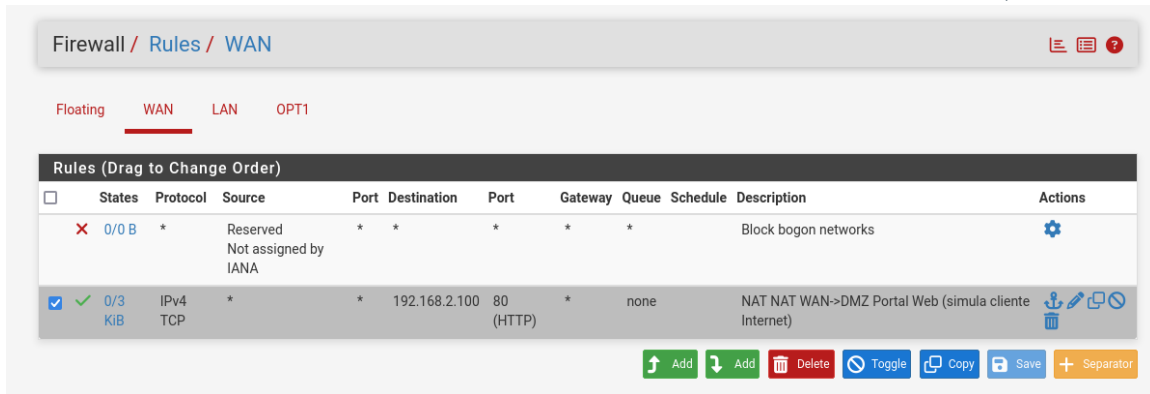
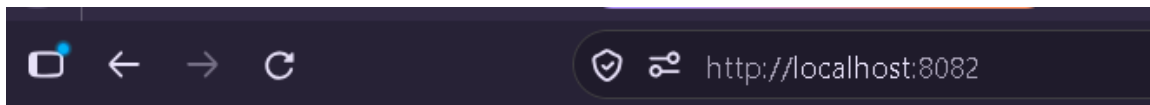


Figura 10. Registro de tráfico bloqueado y regla de denegación.

5.4 Bloquear el acceso directo a MySQL

Se documentó una regla para denegar TCP 3306 hacia el servidor de la DMZ y se observaron entradas de bloqueo en los logs. En una arquitectura real, el acceso a bases de datos suele permitirse únicamente desde los servidores de aplicación que lo necesitan, en lugar de abrirlo a la LAN general.



Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

- [TWiki](#)
- [phpMyAdmin](#)
- [Mutillidae](#)
- [DVWA](#)
- [WebDAV](#)

Figura 11. Regla y registros de intentos hacia TCP 3306.

5.5 Acceso administrativo por SSH

El escenario documenta acceso SSH desde Kali hacia Metasploitable por TCP 2222. La regla solo funciona si el servicio SSH realmente escucha en ese puerto y si tanto pfSense como el firewall local permiten el flujo.

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	4/433 KIB	*	*	*	LAN Address	443 80 22	*	*		Anti-Lockout Rule	
☐	0/0 B	IPv4 TCP	LAN subnets	*	192.168.2.100	80 (HTTP)	*	none		Permitir acceso LAN a portal web DMZ	

Figura 12. Evidencia de sesión SSH administrativa.

6. Publicación controlada del servicio web mediante NAT

El documento original incluye un ejercicio de port forwarding desde la red NAT de VirtualBox hacia el servidor de la DMZ. Se probaron accesos desde el host Windows y se identificó que la protección de bloqueo de redes privadas de la interfaz WAN afectaba al escenario de prueba porque la WAN simulada utilizaba una dirección privada.

```
[x]-[user@parrot]-[~]
$ sudo nmap -Pn -p 2222 192.168.2.100
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-10-10 16:57 UTC
Nmap scan report for 192.168.2.100
Host is up.

PORT      STATE      SERVICE
2222/tcp  filtered  EtherNetIP-1
```

Figura 13. Configuración de port forwarding en VirtualBox.

```
[user@parrot]-[~]
$ ping -c 4 192.168.2.100
PING 192.168.2.100 (192.168.2.100) 56(84) bytes of data.
64 bytes from 192.168.2.100: icmp_seq=1 ttl=63 time=1.05 ms
64 bytes from 192.168.2.100: icmp_seq=2 ttl=63 time=1.18 ms
64 bytes from 192.168.2.100: icmp_seq=3 ttl=63 time=1.17 ms
64 bytes from 192.168.2.100: icmp_seq=4 ttl=63 time=2.43 ms

--- 192.168.2.100 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3172ms
rtt min/avg/max/mdev = 1.045/1.455/2.434/0.567 ms
```

Figura 14. Regla WAN y protección de bloqueo de redes privadas (captura del documento original).

Consideración de seguridad: no se debe desactivar esta protección de forma general en una interfaz WAN de producción. En el laboratorio debe documentarse el cambio temporal y restaurarse al finalizar; una WAN con

dirección privada no es equivalente a una conexión pública real. El port forwarding por sí solo no garantiza conectividad: también deben coincidir el destino NAT, la regla WAN, el servicio de destino, la ruta y el firewall del host.

7. Firewall local en Metasploitable: defensa en profundidad

El firewall de host complementa a pfSense: pfSense filtra el tráfico entre segmentos y el firewall local aplica controles en el propio servidor. La configuración debe probarse con acceso a consola local porque una política de entrada restrictiva puede cortar la administración remota.

7.1 Reglas iptables incluidas en el laboratorio

```
# ATENCIÓN: ejemplo de laboratorio; revisar acceso de recuperación antes de aplicar.
sudo iptables -F
sudo iptables -X

sudo iptables -P INPUT DROP
sudo iptables -P FORWARD DROP
sudo iptables -P OUTPUT ACCEPT

sudo iptables -A INPUT -i lo -j ACCEPT
sudo iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT

sudo iptables -A INPUT -p tcp --dport 80 -j ACCEPT
sudo iptables -A INPUT -p tcp --dport 21 -s 192.168.1.102 -j ACCEPT
sudo iptables -A INPUT -p tcp --dport 2222 -s 192.168.1.100 -j ACCEPT

sudo iptables -A INPUT -p tcp --dport 3306 -j LOG --log-prefix "DB-ACCESS-BLOCKED: "
sudo iptables -A INPUT -p tcp --dport 3306 -j DROP

sudo iptables -A INPUT -p icmp --icmp-type echo-request -j ACCEPT
sudo iptables -A INPUT -j LOG --log-prefix "HOST-FW-BLOCKED: "
sudo iptables -A INPUT -j DROP
```

Interpretación: INPUT DROP deniega conexiones entrantes no autorizadas; FORWARD DROP evita el reenvío de tráfico a través del host; OUTPUT ACCEPT permite tráfico originado por el propio servidor. Loopback y conexiones establecidas se permiten, HTTP queda disponible, FTP se limita al proveedor, SSH al equipo Kali, MySQL se bloquea y registra, ICMP Echo Request se permite y el resto del tráfico entrante se registra y descarta.

Limitaciones que deben quedar explícitas: la regla HTTP permite cualquier origen que pueda alcanzar el host; OUTPUT ACCEPT no aplica mínimo privilegio al egress; el puerto SSH debe coincidir con el puerto real de escucha; las reglas locales no sustituyen el filtrado de pfSense. El comando -F/-X elimina reglas existentes y no debe ejecutarse en producción sin plan de recuperación.

7.2 Alternativa con UFW

```
# ATENCIÓN: reset elimina reglas UFW existentes; usar solo en laboratorio.
sudo ufw --force reset
sudo ufw default deny incoming
sudo ufw default allow outgoing

sudo ufw allow 80/tcp comment 'Portal web - acceso de laboratorio'
sudo ufw allow from 192.168.1.102 to any port 21 proto tcp comment 'FTP solo proveedor'
sudo ufw allow from 192.168.1.100 to any port 2222 proto tcp comment 'SSH admin solo Kali'
sudo ufw deny 3306/tcp comment 'DB bloqueada - no exponer'
```

```
sudo ufw logging on
sudo ufw --force enable
sudo ufw status numbered
```

UFW es una interfaz simplificada para gestionar reglas de firewall en Linux. La política equivalente se expresa con comandos más sencillos, pero deben validarse los mismos aspectos: servicio activo, IP de origen, puerto real, orden de reglas, políticas predeterminadas y conectividad de administración.

8. Plan de validación funcional

Prueba	Origen	Resultado esperado	Evidencia
HTTP TCP 80	Kali / Parrot autorizados	Conexión HTTP permitida	curl -I y captura
FTP TCP 21	Parrot	Conexión permitida	nc y log de pfSense
FTP TCP 21	Kali u otro origen no autorizado	Conexión bloqueada	nc y log de bloqueo
SSH TCP 2222	Kali	Acceso administrativo permitido	nc/SSH y captura
SSH TCP 2222	Parrot	Conexión bloqueada	nc y log
MySQL TCP 3306	Kali/Parrot	Acceso directo bloqueado	nc y log
ICMP Echo	LAN hacia DMZ	Permitido según política	ping
Puertos no autorizados	LAN hacia DMZ	Filtrados/bloqueados	Nmap y logs

Los resultados esperados no deben presentarse como comprobados si no existe evidencia de la prueba correspondiente. Un puerto `filtered` en Nmap indica que el escaneo no pudo determinar si está abierto, habitualmente por filtrado o ausencia de respuesta; no equivale a demostrar por sí solo qué regla lo bloqueó.

9. Hallazgos y mejoras recomendadas

- La configuración inicial incluía una regla amplia en LAN que debía revisarse frente al principio de mínimo privilegio.
- El escaneo inicial identificó múltiples servicios en Metasploitable; la superficie expuesta debe reducirse a los servicios justificados.
- La segmentación debe limitar las conexiones LAN→DMZ y evitar conexiones nuevas DMZ→LAN que no estén autorizadas.
- FTP y Telnet son protocolos heredados que no cifran adecuadamente las credenciales; no deben usarse para transferir información sensible en producción.
- Las bases de datos deben aceptar conexiones solo desde los sistemas de aplicación autorizados.
- Las reglas de administración deben limitarse a orígenes de confianza y protegerse con autenticación robusta.
- Los registros deben permitir correlacionar origen, destino, puerto, interfaz, regla coincidente y hora.
- La protección de bloqueo de redes privadas en la interfaz WAN debe mantenerse en una WAN pública real; cualquier excepción de laboratorio debe ser temporal y documentada.
- El firewall local y pfSense deben configurarse de manera complementaria y probarse por separado para identificar dónde se produce un bloqueo.

10. Conclusión

El laboratorio demuestra un método práctico para evaluar y mejorar la seguridad perimetral: inventariar los servicios accesibles, definir una matriz de acceso, restringir los flujos a los orígenes autorizados, bloquear el acceso directo a servicios sensibles y validar el resultado mediante pruebas y logs. La defensa en profundidad se consigue combinando el filtrado entre redes de pfSense con controles locales en el servidor Linux.

La principal evidencia de éxito no es la cantidad de reglas creadas, sino la correspondencia entre la política definida y los resultados observados: los flujos necesarios funcionan, los no autorizados se bloquean y los eventos relevantes quedan registrados.

Anexo A. Comandos de consulta

```
# pfSense: revisar logs desde la interfaz web
Status > System Logs > Firewall

# Linux / iptables
sudo iptables -L -n -v
sudo iptables -S
sudo ss -lntp

# UFW
sudo ufw status verbose
sudo ufw status numbered

# Validación desde los clientes del laboratorio
nmap -Pn -sV --top-ports 100 192.168.2.100
nc -vz -w 3 192.168.2.100 21
nc -vz -w 3 192.168.2.100 2222
curl --connect-timeout 3 -I http://192.168.2.100/
```

Clasificación: proyecto educativo de laboratorio. Las direcciones IP, capturas y resultados corresponden al entorno documentado. Antes de publicar, revisar que las imágenes no incluyan credenciales, tokens, direcciones públicas u otra información sensible.